

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

PIANO DI ADEGUAMENTO

MISURE TECNICHE, OPERATIVE E ORGANIZZATIVE (MTOM)

Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-PLN009_00	00	29/04/2026	8
Redatto da	Approvato da	Classificazione	Stato
AD – Francesco Epifani / RSGI	AD – Francesco Epifani	Riservato Alta Direzione + ACN	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
29/04/2026	29/04/2026	29/04/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

1. Scopo e ambito di applicazione

Il presente Piano formalizza, in attuazione dell'art. 24 del D.Lgs. 4 settembre 2024 n. 138 (recepimento della Direttiva (UE) 2022/2555 — NIS2) e della Determinazione del Direttore Generale dell'Agenzia per la Cybersicurezza Nazionale n. 38565 del 26 giugno 2025, l'adeguamento di Toscana Diagnostica S.r.l. alle dieci aree di Misure Tecniche, Operative e Organizzative (MTOM) richieste ai soggetti destinatari di obblighi NIS2.

Il Piano dichiara, per ciascuna delle dieci aree MTOM, lo stato attuale (as-is), lo stato obiettivo (to-be), il responsabile (owner), la scadenza, l'evidenza documentale prevista e lo stato di avanzamento. È redatto dall'Amministratore Delegato con il supporto del RSGI in coerenza con TD-SGI-PRO070_00 §7 e ne costituisce il documento operativo di riferimento.

L'attuazione integrale è programmata entro il 1° ottobre 2026 (scadenza vincolante D.Lgs. 138/2024 e Determinazioni ACN attuative). Il Piano è oggetto di Riesame della Direzione semestrale e di audit interno annuale.

2. Dati generali del soggetto NIS

Voce	Dato
Ragione sociale	Toscana Diagnostica S.r.l.
P.IVA / CF	07528130482
Sede legale	Viale Belfiore 55, 50144 Firenze (FI)
Settore	Sanità — Laboratori di analisi cliniche e diagnostica per immagini
Codice DNISA aziendale (registrazione ACN)	DNISA00056699 — registrato il 27/04/2026
Categoria NIS	Soggetto Importante (autovalutazione art. 6 D.Lgs. 138/2024)
Punto di Contatto NIS	AD – Francesco Epifani (TD-SGI-MOD200_00)
Sostituto PdC NIS	RSGI (TD-SGI-MOD200_00)
Scadenza vincolante MTOM	1° ottobre 2026

3. Riferimenti normativi e documentali

Riferimento	Ambito
Direttiva (UE) 2022/2555 (NIS2)	Quadro europeo cybersecurity
D.Lgs. 4 settembre 2024 n. 138 art. 24	MTOM, gestione del rischio
D.Lgs. 4 settembre 2024 n. 138 art. 25	Notifiche di incidente
Determinazione ACN n. 38565 del 26/06/2025	MTOM operativo per soggetti importanti
ISO/IEC 27001:2022 + Annex A	Information Security Management System
ISO/IEC 27002:2022	Controlli di sicurezza informatica
ISO/IEC 27005:2022	Risk management ISMS
NIST CSF 2.0 (riferimento metodologico)	Identify-Protect-Detect-Respond-Recover-Govern
TD-SGI-PRO070_00	Procedura NIS2
TD-SGI-MOD181-184, IDL026, MOD200	Moduli satellite NIS2
TD-SGI-PRO017 / PRO019 /	Procedure SGI integrate

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

PRO034 / PRO057

4. Governance e ruoli

Ruolo	Responsabilità sul Piano MTOM
AD / Punto di Contatto NIS	Approvazione del Piano e delle revisioni; rappresentanza verso ACN; allocazione risorse; rendicontazione al CdA
RSOI	Coordinamento operativo del Piano, allineamento con SGI multi-norma, monitoraggio KPI, audit interno annuale, supporto tecnico-redazionale
IT Manager	Esecuzione operativa delle MTOM tecniche (controlli A.5-A.8 ISO 27001:2022); manutenzione dell'inventario asset e delle configurazioni
DPO	Coordinamento con privacy by design e accountability GDPR; valutazione data breach
RSPP	Coordinamento con safety operativa per MTOM area sicurezza fisica e ambientale
MSSP / SOC esterno	Detection, threat intelligence, incident response Tier-1/Tier-2 — fornitore critico
OdV 231	Verifica che il Piano sia coerente con le esigenze di prevenzione del rischio cyber-reato
Internal Auditor	Audit interno annuale NIS2

5. Mappa delle 10 aree MTOM

La Determinazione ACN n. 38565/2025 prevede 10 macro-aree MTOM, mappate su ISO/IEC 27001:2022 Annex A.

#	Area MTOM (art. 24 c. 2 D.Lgs. 138/2024)	Riferimento ISO/IEC 27001:2022 Annex A
1	Politiche di analisi del rischio e di sicurezza dei sistemi informativi	A.5 (controlli organizzativi)
2	Gestione degli incidenti	A.5.24-A.5.28 (incident management)
3	Continuità operativa e gestione delle crisi	A.5.29-A.5.30 (business continuity)
4	Sicurezza della catena di approvvigionamento	A.5.19-A.5.23 (supplier relationships)
5	Sicurezza dell'acquisizione, sviluppo e manutenzione di sistemi	A.8.25-A.8.34 (secure development)
6	Politiche e procedure per valutare l'efficacia delle misure	A.5.35 (independent review) + A.6.8 (assurance)
7	Pratiche di igiene informatica di base e formazione in cybersecurity	A.6.3 (awareness) + A.8.7 (malware)
8	Politiche e procedure relative all'uso della crittografia e cifratura	A.8.24 (cryptography)
9	Sicurezza delle risorse umane, controllo degli accessi e gestione degli asset	A.6 (people) + A.5.15-A.5.18 (access) + A.5.9-A.5.14 (asset)
10	Uso di MFA, soluzioni di comunicazione protetta e autenticazione continua	A.8.5 (secure authentication) + A.8.21 (network security)

6. Schede operative per le 10 aree MTOM

Per ciascuna area è riportata la scheda operativa nel formato (As-is — To-be — Owner — Scadenza — Evidenza — Stato). Le scadenze sono allineate al vincolo del 1° ottobre 2026; i valori indicati come "In corso" sono soggetti a verifica trimestrale dal RSGI.

6.1 Area 1 — Politiche di analisi del rischio e sicurezza dei sistemi informativi

Voce	Contenuto
As-is	Politica di sicurezza informatica TD-SGI-POL001 in vigore. Risk assessment su ISO 27005 effettuato annualmente. Statement of Applicability ISO 27001 in bozza.
To-be	Politica NIS2-specifica integrata in POL001 entro 30/06/2026. Risk register con metriche quantitative e tracciatura trattamenti del rischio. SoA approvato dal CdA. Risk assessment NIS2-driven mappato su threat model sanitario.
Owner	RSGI + IT Manager
Scadenza	30/06/2026 (politica integrata) — 31/08/2026 (SoA approvato) — 1/10/2026 (risk register operativo)
Evidenza	POL001 rev 02; SoA firmato dal CdA; Risk Register tenuto in MOD039; verbali Riesame Direzione
Stato	In corso — completamento al 50%

6.2 Area 2 — Gestione degli incidenti

Voce	Contenuto
As-is	PRO070 in vigore. PRO019 (gestione eventi indesiderati ICT) in vigore. SOC 24x7 esternalizzato. MOD181, MOD184, IDL026 emessi 29/04/2026.
To-be	Esercitazione tabletop NIS2 svolta entro 30/09/2026 con verbale MOD183 sottoscritto. Almeno 1 incidente significativo simulato end-to-end. Tempistiche T0+24h/72h/30gg validate operativamente.
Owner	PdC NIS + IT Manager + RSGI
Scadenza	30/09/2026 (tabletop completato)
Evidenza	MOD183 sottoscritto; ricevute Portale ACN della simulazione; lessons learned documentate
Stato	In corso — 70% (procedurale completo, esecutivo da svolgere)

6.3 Area 3 — Continuità operativa e gestione delle crisi

Voce	Contenuto
As-is	Backup giornaliero LIS/RIS/PACS con retention 90 giorni. Disaster Recovery Plan in bozza. Test di ripristino effettuato 1 volta nel 2025. Nessun BCP formalizzato per crisi cyber.
To-be	BCP NIS2-compatibile coerente con ISO 22301 (target di certificazione 2027). DRP formalmente approvato con RTO ≤ 4h per servizi critici (LIS), RTO ≤ 8h per servizi importanti. Test di ripristino full-scale 2/anno. Crisis Management Plan distinto dal DRP.
Owner	IT Manager + AD + Direttore Sanitario
Scadenza	31/07/2026 (BCP+DRP approvati) — 30/09/2026 (test full-scale completato)
Evidenza	BCP approvato dal CdA, DRP firmato, log test ripristino, MOD061 (verbali test BCP)
Stato	In corso — 30% (gap su BCP formalizzato e test full-scale)

6.4 Area 4 — Sicurezza della catena di approvvigionamento

Voce	Contenuto
As-is	Qualifica fornitori PRO017 in vigore. DPA ex art. 28 GDPR sottoscritti con tutti i fornitori che trattano dati personali. Inventario fornitori ICT MOD182 emesso 29/04/2026 (in popolamento operativo).
To-be	MOD182 popolato e validato entro 31/05/2026. 8 clausole NIS2 contrattuali (PRO070 §9) inserite in tutti i contratti di fornitori critici entro 31/12/2026 (90% al 1/10/2026). Audit di terza parte programmati per fornitori critici (rotazione triennale, 30%/anno).
Owner	IT Manager + Procurement + Legal
Scadenza	31/05/2026 (MOD182 popolato) — 1/10/2026 (90% clausole inserite) — 31/12/2026 (100%)
Evidenza	MOD182 popolato; addendum contrattuali firmati; piano audit fornitori
Stato	In corso — 40% (MOD182 emesso, popolamento e clausole da completare)

6.5 Area 5 — Sicurezza acquisizione, sviluppo e manutenzione di sistemi

Voce	Contenuto
As-is	Sviluppo software interno limitato (script automazione). Maggior parte sistemi acquisiti come SaaS/On-prem da fornitori (LIS, RIS/PACS). Patch management trimestrale gestito da IT Manager con MSSP.
To-be	Procedura formale di gestione delle modifiche (change management) con classificazione rischio — emissione PRO086 entro 31/07/2026. Vulnerability assessment annuale + penetration test almeno 1/anno (programma 2026 da definire). Patch management mensile per sistemi critici.
Owner	IT Manager + RSGI
Scadenza	31/07/2026 (PRO086 emessa) — 30/09/2026 (primo VAPT 2026 completato)
Evidenza	PRO086; report VAPT firmato dal fornitore terzo; registro patch
Stato	In corso — 25% (gap su procedura formale e cadenza VAPT)

6.6 Area 6 — Valutazione efficacia delle misure

Voce	Contenuto
As-is	Audit interno SGI annuale. Riesame Direzione annuale. Nessun audit interno NIS2-specifico ancora svolto.
To-be	Audit interno NIS2 1/anno coerente con TD-SGI-PRO007. Misurazione KPI NIS2 (10 indicatori chiave) mensile. Riesame Direzione semestrale dedicato a NIS2 e SGI integrato.
Owner	RSGI + Internal Auditor
Scadenza	30/09/2026 (primo audit interno NIS2 completato)
Evidenza	Verbale audit interno NIS2; cruscotto KPI; verbale Riesame
Stato	In corso — 20% (programma audit definito, esecuzione da svolgere)

6.7 Area 7 — Igiene informatica e formazione in cybersecurity

Voce	Contenuto
As-is	Formazione su privacy/sicurezza in onboarding obbligatoria. Campagne phishing simulate non sistematiche. Antivirus/EDR su tutti gli endpoint. Password policy attiva ma debolezza su rotazione/lunghezza.
To-be	Piano formativo NIS2 con 8 ore/anno per tutto il personale e 16 ore/anno per ruoli ICT/Alta Direzione, erogato da gennaio 2026. Phishing test 4/anno con report. Hardening baseline endpoint applicato (CIS Benchmark Tier 1).

	Password policy aggiornata a NIST SP 800-63B.
Owner	RSGI + IT Manager + P&C
Scadenza	30/06/2026 (piano formativo erogato Q1-Q2) — 30/09/2026 (hardening 100%)
Evidenza	MOD007 (registro formazione); report phishing; baseline endpoint; policy password
Stato	In corso — 35% (formazione partita, hardening da completare)

6.8 Area 8 — Crittografia e cifratura

Voce	Contenuto
As-is	Cifratura at-rest sui database LIS/RIS/PACS. Cifratura in-transit TLS 1.2/1.3 su tutti i servizi web. Backup off-site cifrati. Gestione chiavi non centralizzata.
To-be	Politica di cifratura formalizzata (POL003) con riferimenti a curve ellittiche, AES-256-GCM, post-quantum readiness. Key management centralizzato (KMS o HSM) con rotazione automatizzata. Cifratura at-rest su tutti gli endpoint (BitLocker/FileVault). Tunnel VPN sostituiti con ZTNA per accesso remoto.
Owner	IT Manager + RSGI
Scadenza	31/07/2026 (POL003 emessa) — 1/10/2026 (KMS centralizzato + ZTNA + endpoint encryption)
Evidenza	POL003; configurazione KMS; report endpoint encryption; topologia ZTNA
Stato	In corso — 45% (cifratura base ok, gap su gestione chiavi e ZTNA)

6.9 Area 9 — Sicurezza risorse umane, controllo accessi, gestione asset

Voce	Contenuto
As-is	Gestione utenze su Active Directory + IAM nativo applicativo. Joiner/Mover/Leaver gestito da P&C con ticket IT. Inventario asset MOD050 in vigore con copertura ~80% degli endpoint. Background check personale strategico effettuato all'assunzione.
To-be	JML automatizzato con disattivazione T+0 al ticket di cessazione. RBAC documentato e segregazione duties. Inventario asset 100% (CMDB attiva). Privileged Access Management (PAM) con vault, session recording per amministratori. Background check ricorrente per ruoli critici.
Owner	IT Manager + P&C
Scadenza	31/08/2026 (JML automation + inventario 100%) — 1/10/2026 (PAM operativo)
Evidenza	Documentazione RBAC; CMDB con copertura; configurazione PAM; report disattivazioni JML
Stato	In corso — 40%

6.10 Area 10 — MFA, comunicazione protetta, autenticazione continua

Voce	Contenuto
As-is	MFA attivo su mail, VPN, console amministrativa, ma non uniformemente su tutti i servizi SaaS. Autenticazione standard su LIS/RIS/PACS. Comunicazioni cliniche via portale paziente con HTTPS.
To-be	MFA universale su tutti i servizi (interni ed esterni) entro 30/09/2026. SSO + adaptive authentication per servizi ad alto rischio. Risk-based authentication (login impossibile, geo-anomalie, device anomali). Trasformazione del portale paziente in piattaforma con autenticazione SPID/CIE-compatibile.

Owner	IT Manager
Scadenza	30/09/2026 (MFA universale) — 31/12/2026 (SPID/CIE su portale paziente)
Evidenza	Inventario servizi con MFA on/off; configurazione SSO; log adaptive auth
Stato	In corso — 60% (MFA su sistemi core, gap su SaaS minori e portale paziente)

7. Riepilogo cruscotto

Area	Stato % 29/04/2026	al	Scadenza intermedia	Scadenza finale
A1 – Politiche e risk management	50%		30/06/2026 (politica integrata)	1/10/2026
A2 – Gestione incidenti	70%		—	30/09/2026 (tabletop)
A3 – Continuità e crisi	30%		31/07/2026 (BCP+DRP)	30/09/2026 (test full-scale)
A4 – Catena di approvvigionamento	40%		31/05/2026 (MOD182 popolato)	31/12/2026 (clausole 100%)
A5 – Sviluppo e manutenzione	25%		31/07/2026 (PRO086)	30/09/2026 (1° VAPT)
A6 – Valutazione efficacia	20%		—	30/09/2026 (audit NIS2)
A7 – Igiene informatica e formazione	35%		30/06/2026 (formazione)	30/09/2026 (hardening)
A8 – Crittografia e cifratura	45%		31/07/2026 (POL003)	1/10/2026 (KMS + ZTNA)
A9 – RU, accessi, asset	40%		31/08/2026 (JML+inventario)	1/10/2026 (PAM)
A10 – MFA, comunicazione, auth continua	60%		—	30/09/2026 (MFA universale)

Stato medio aggregato al 29/04/2026: 41,5%. Trend richiesto: 70% al 30/06/2026, 90% al 31/08/2026, 100% al 1/10/2026.

8. Indicatori di adeguamento

KPI	Formula	Target 1/10/2026
% MTOM in stato "completo"	Aree complete / 10	100%
% MTOM in stato "≥80%"	Aree ≥ 80% / 10	100% (entro 31/08/2026)
Numero scadenze rispettate	Scadenze rispettate / Scadenze totali	≥ 95%
% personale formato sul piano NIS2	Formati / Totale	≥ 95%
% endpoint con baseline hardening applicata	Endpoint hardenati / Totale	100%
% fornitori critici con clausole NIS2	Critici con clausole / Totale critici	≥ 90% (al 1/10/2026)
Numero VAPT completati nell'anno	Conteggio diretto	≥ 1
Numero esercitazioni tabletop completate	Conteggio diretto	≥ 1

9. Piano di monitoraggio e governance del Piano

Il presente Piano è strumento operativo dinamico. Il monitoraggio è strutturato come segue:

- (a) revisione mensile RSGI + IT Manager con aggiornamento dello stato % di ciascuna area;
- (b) reportistica trimestrale al CdA dell'avanzamento aggregato e degli scostamenti;
- (c) Riesame della Direzione semestrale dedicato a NIS2 con esame del Piano e adozione di azioni correttive;
- (d) audit interno annuale a cura del RSGI o di Auditor terzo qualificato;
- (e) revisione del Piano (rev 01) entro 31/07/2026 con consolidamento delle scadenze finali e degli stati intermedi;
- (f) chiusura formale del Piano entro 31/12/2026 con dossier di evidenze opponibile in ispezione ACN.

10. Rischi e contromisure

Rischio	Probabilità	Impatto	Contromisura
Mancato rispetto della scadenza 1/10/2026	Media	Alto (sanzioni ACN, reputazione)	Cruscotto mensile + escalation CdA + supporto consulenza specializzata se necessario
Vincoli economici sull'investimento	Media	Medio	Allocazione di budget dedicato approvata dal CdA, verifica trimestrale
Resistenza organizzativa al cambiamento (personale)	Media	Medio	Piano formativo specifico, comunicazione interna ad personam, sponsorship Alta Direzione
Dipendenza da fornitori critici per implementazione	Media	Alto	Anticipazione contrattuale e KPI fornitore con SLA penali
Compresenza di altre scadenze normative (EHDS, AI Act, ISO 15189)	Alta	Medio	Sequenziamento priorità, supporto RSGI a coordinamento, riuso sinergie ISO 27001/27701

11. Storico delle revisioni

Rev.	Data	Descrizione	Redatto	Approvato
00	29/04/2026	Prima emissione del Piano di Adeguamento MTOM in attuazione di TD-SGI-PRO070_00 §7.2 e dell'art. 24 D.Lgs. 138/2024.	AD + RSGI	AD